Resumen 3

Concepto de riesgo

Es la probabilidad que una amenaza informática se pueda materializar sobre un activo y a la vez provocar un impacto que ocasione pérdidas o daños materiales o inmateriales.

Riesgo
DATA
PROTECTION

Tipos de riesgo

No todas las amenazas informáticas pueden generar el mismo impacto en un activo, esto nos permite poder clasificar los riesgos en varios niveles los cuales son:

- **Alto:** el impacto generado sobre la organización a muy corto plazo puede ocasionar pérdidas o desarticulación de sus procesos core del negocio.
- **Medio:** el impacto provocado no es tan evidente en el corto plazo, pero si no se corrige con el tiempo puede generar pérdidas o desarticulación de la organización.
- **Bajo:** el impacto causa un daño aislado, que no perjudica a ningún componente de la organización.

El análisis de riesgos es el primer punto de la gestión de la seguridad de la información de una organización, y es necesario para realizar la gestión de los riesgos, es decir, tomar la decisión de eliminarlos, ignorarlos, transferirlos o mitigarlos y controlarlos, es decir realizar la gestión de riesgos

Matriz de riesgos informáticos

La construcción de la matriz de riesgos informáticos en una organización es el insumo más importante para identificar cuáles son esos activos que son necesarios para el cumplimiento de su misión y visión, toda vez que permite conocer cuáles son esas amenazas y la probabilidad de que tienen cada una de ellas de materializarse y provocar un impacto determinado en la organización, el identificarlas nos facilitara el proceso de definir y seleccionar cuales son las alternativas de mitigación que se podrán aplicar a fin de poder realizar una gestión adecuada del riesgo.

Fundamentos de la matriz de riesgos

La matriz se basa en el método de análisis de riesgo con un grado de riesgo, usando la fórmula:

Riesgo = probabilidad de amenaza y magnitud de daño (impacto)

La probabilidad de amenaza y magnitud de daño pueden tomar los valores y condiciones respectivamente:

1 = Insignificante (incluido Ninguna)
2 = Baja
3 = Mediana
4 = Alta

El riesgo, que es el producto de la multiplicación de Probabilidad de Amenaza por Magnitud de Daño, está agrupado en tres rangos, y para su mejor visualización, se aplica diferentes colores.

Bajo Riesgo = 1 – 6 (Verde)

Medio Riesgo = 8 – 9 (Amarillo)

Alto Riesgo = 12 – 16 (Rojo)

Uso de la matriz

En la columna datos e información se deben de ingresar todos los activos identificados previamente en las fases anteriores de acuerdo a su clasificación y valuación, es donde debemos ingresar los sistemas de información, equipos, personal entre otros que de acuerdo a la valuación de activos se determine son importantes y necesarios para que la empresa pueda lograr el cumplimiento de sus objetivos.

En la clasificación se debe seleccionar según el análisis previo a que tipos de criterios podría verse afectado el activo, esta clasificación puede ser de tres tipos:

Confidencial, privado, sensitivo

Obligación por ley / Contrato / Convenio

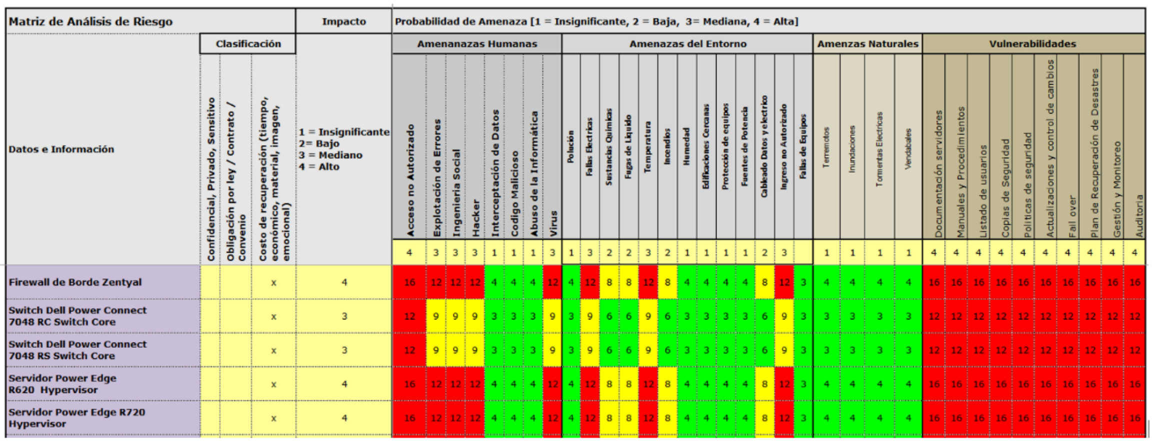
Costo de recuperación (tiempo, económico, material, imagen, emocional)

Esta clasificación obedece a entender e identificar en cuál de las anteriores clasificaciones puede estar inmerso el activo a fin de poder definir su impacto y nivel de importancia que tiene para la operación de la organización.

El siguiente paso será valuar la probabilidad de las amenazas que podrían surtir algún efecto sobre los ACTIVOS ocasionando pérdidas materiales o inmateriales de estos, para ello se debe dar un valor para cada una de ellas, estos valores pueden ser los siguientes:

Probabilidad de Amenaza [1 = Insignificante, 2 = Baja, 3= Mediana, 4 = Alta]

De esta manera la matriz hace el cálculo automático y permite valuar el riesgo informático logrando de esta manera tener una matriz de riesgos lista para su posterior análisis y desarrollo del plan de tratamiento de riesgos.



Matriz de Análisis de Riesgo				Impacto	Probabilidad de Amenaza [1 = Insignificante, 2 = Baja, 3= Mediana, 4 = Alta]																																	
	Clasificación				Amenanazas Humanas								Amenazas del Entorno													Amenzas Naturales				Vulnerabilidades									
Datos e Información	Confidencial, Privado, Sensitivo	Obligación por ley / Contrato / Convenio	Costo de recuperación (tiempo, económico, material, imagen, emocional)	1 = Insignificante 2= Bajo 3 = Mediano 4 = Alto	Acceso no Autorizado	Explotación de Errores	Ingenieria Social	Hacker	Interceptación de Datos	Codigo Malicioso	Abuso de la Informática	Virus	Polución	Fallas Electricas	Sustancias Quimicas	Fugas de Liquido	Temperatura	Incendios	Humedad	Edificaciones Cercanas	Protección de equipos	Fuentes de Potencia	Cableado Datos y electrico	Ingreso no Autorizado	Fallas de Equipos	Terremotos	Inundaciones	Tormentas Electricas	Vendabales	Documentación servidores	Manuales y Procedimientos	Listado de usuarios	Copias de Seguridad	Politicas de seguridad	Actualizaciones y control de cambios	Fail over	Plan de Recuperación de Desastres	Gestión y Monitoreo	Auditoria
					4	3	3	3	1	1	1	3	1	3	2	2	3	2	1	1	1	1	2	3		1	1	1	1	4	4	4	4	4	4	4	4	4	4
Firewall de Borde Zentyal			x	4	16	12	12	12	4	4	4	12	4	12	8	8	12	8	4	4	4	4	8	12	3	4	4	4	4	16	16	16	16	16	16	16	16	16	16
Switch Dell Power Connect 7048 RC Switch Core			x	3	12	9	9	9	3	3	3	9	3	9	6	6	9	6	3	3	3	3	6	9	3	3	3	3	3	12	12	12	12	12	12	12	12	12	12
Switch Dell Power Connect 7048 RS Switch Core			x	3	12	9	9	9	3	3	3	9	3	9	6	6	9	6	3	3	3	3	6	9	3	3	3	3	3	12	12	12	12	12	12	12	12	12	12
Servidor Power Edge R620 Hypervisor			x	4	16	12	12	12	4	4	4	12	4	12	8	8	12	8	4	4	4	4	8	12	3	4	4	4	4	16	16	16	16	16	16	16	16	16	16
Servidor Power Edge R720 Hypervisor			x	4	16	12	12	12	4	4	4	12	4	12	8	8	12	8	4	4	4	4	8	12	3	4	4	4	4	16	16	16	16	16	16	16	16	16	16

Matriz de riesgo construida

Dependiendo del color de cada celda, podemos sacar conclusiones no solo sobre el nivel de riesgo que corre cada elemento de información de sufrir un daño significativo, causado por una amenaza, sino también sobre las medidas de protección necesarias. (Velázquez Martínez, 2011).

Adaptación de la matriz

La matriz trabaja con una colección de diferentes amenazas y elementos de información. Ambas colecciones solo representan una aproximación a la situación común de una organización, pero no necesariamente reflejan la realidad de una organización específica. Entonces si hay necesidad de adaptar la matriz a la situación real de una organización, solo hay que ajustar los valores de las amenazas y de los datos de información.